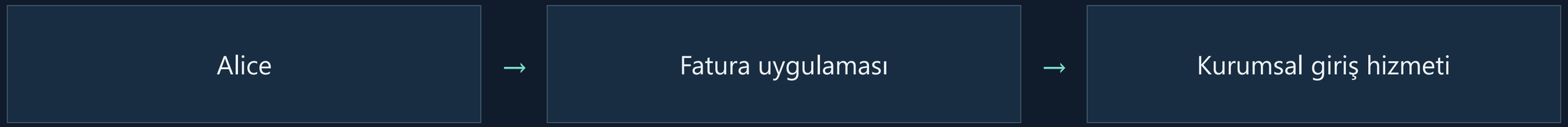
JWT, OAuth ve SSO

Kurumsal giriş ve güvenli loglama

Bir fatura uygulamasında girişin, erişimin ve olay kaydının nasıl çalıştığı.



Kurumsal hesapla giriş



Alice, “Kurumsal hesapla giriş” düğmesine basıyor. Hesabını doğruladıktan sonra faturalarına dönüyor.

Uygulama, giriş sonucunu kontrol edip Alice için kendi oturumunu açıyor.

Dört isim, dört farklı görev

İsim	Bu dersteki anlamı
JWT · JSON Web Token	Kullanıcı ve erişim bilgilerini taşıyabilen bir veri biçimi.
OAuth 2.0	Bir uygulamaya sınırlı API erişimi verme yöntemi.
OpenID Connect	OAuth üzerine kurulan, giriş yapan kullanıcının kimliğini doğrulayan standart.
SSO · Single Sign-On	Tek oturum açma: bir girişin birden fazla uygulamada kullanılabilmesi.

OAuth kullanılması, access token'ın mutlaka JWT biçiminde olacağı anlamına gelmez.

RFC 7519 · JWT RFC 6749 · OAuth 2.0 OpenID Connect Core 1.0

JWT içinde ne var?

```
{
  "sub": "user-42",
  "aud": "fatura-api",
  "exp": 1793020200
}
```

Alan	Örnekteki anlamı
sub	Hangi kullanıcı?
aud	Bu token'ı hangi uygulama veya API kabul edebilir?
exp	Ne zamana kadar geçerli?

Bu, imzalı JWT'nin veri bölümüdür. İçeriği okunabilir; parola veya gizli anahtar konulmaz.

RFC 7519 · JWT

JWT için iki anahtar düzeni

Yöntem	Token’ı üreten hizmet	API doğrulaması
Simetrik · HS256	Ortak gizli anahtarla doğrulama etiketi üretir.	Aynı gizli anahtarı kullanır.
Asimetrik · RS256	Özel anahtarla imzalar.	Açık anahtarla doğrular.



HS256’da ortak anahtarı bilen doğrulayıcı da token üretebilir. RS256’da yalnız açık anahtarı olan API imza üretemez. Token üreten hizmetin gizli veya özel anahtarı tarayıcıya verilmez.

RFC 7518 · Anahtarlar ve algoritmalar RFC 8725 · JWT güvenliği

JWT istemcide mi tutulur?

Sunucu token’ı üretir → İstemci token’ı saklar → İstekle API’ye gönderir

Tarayıcıdaki yer	Dikkat edilecek nokta
HttpOnly çerez · Cookie	JavaScript okuyamaz; tarayıcı uygun isteklere ekler. Siteler arası istek koruması ayrıca gerekir.
localStorage / sessionStorage	JavaScript okuyabilir. XSS varsa token ele geçirilebilir.

Kullanıcı ve süre bilgisi token’ın içinde taşınabilir. İmzalı içerik okunabilir; API her istekte imzayı ve izinleri kontrol eder.

Bu, tarayıcıda token tutulan örnektir. JWT sunucuda da saklanabilir; hesap, izin ve iptal kayıtları ayrıca tutulabilir.

OWASP · Oturum ve tarayıcıda saklama RFC 7519 · JWT

İçeriği değiştirmek yetki kazandırmamalı



Saldırgan, token’ın içindeki kullanıcıyı Alice yerine Bob yapabilir. API imzayı doğruluyorsa değişiklik fark edilir.

İmza doğrulanmadan okunan kullanıcı veya rol bilgisiyle erişim verilmez.

RFC 8725 · JWT güvenliği

API token’da neleri kontrol eder?

Kontrol	Sorulacak soru
İmza	Token’ın içeriği değiştirilmiş mi?
Üretici	Token güvendiğimiz giriş hizmetinden mi geliyor?
Hedef	Bu token bizim API’miz için mi üretilmiş?
Süre	Hâlâ geçerli mi?

Bu kontroller geçse bile kullanıcının istenen faturaya erişim izni ayrıca denetlenir.

RFC 8725 · JWT güvenliği OWASP · Authorization Cheat Sheet

Kısa bir JWT doğrulama örneği

```
import jwt

def verify_token(token, public_key):
    return jwt.decode(
        token, public_key, algorithms=["RS256"],
        issuer="https://idp.example.test/",
        audience="fatura-api",
        options={"require": ["exp", "iss", "aud", "sub"]}
    )
```

public_key, güvenilir giriş hizmetinden alınmış açık anahtardır. Doğrulama başarısızsa istek reddedilir.

PyJWT · Kullanım belgeleri RFC 8725 · JWT güvenliği

Geçerli token, her faturaya erişim izni vermez

```
GET /invoices/102 HTTP/1.1
Host: api.example.test
Authorization: Bearer <access_token>
```

Alice’in kimliği doğrulandı → 102 numaralı fatura Bob’un → Erişim reddedilir

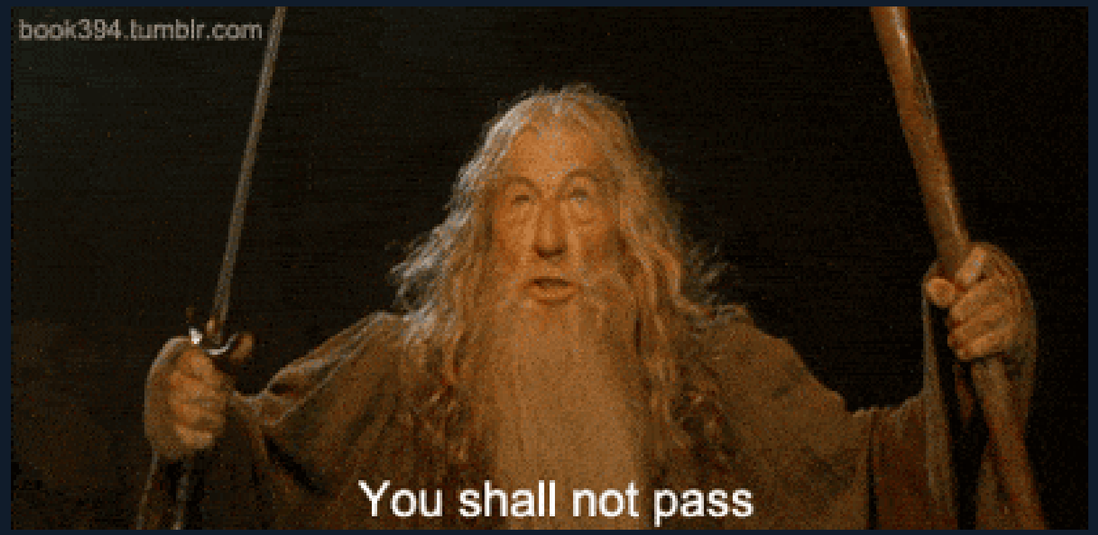
6. haftadaki şirket ve sahiplik kontrolleri burada da uygulanır.

RFC 6750 · Bearer token OWASP · Authorization Cheat Sheet

OAuth: başka bir uygulamaya sınırlı izin

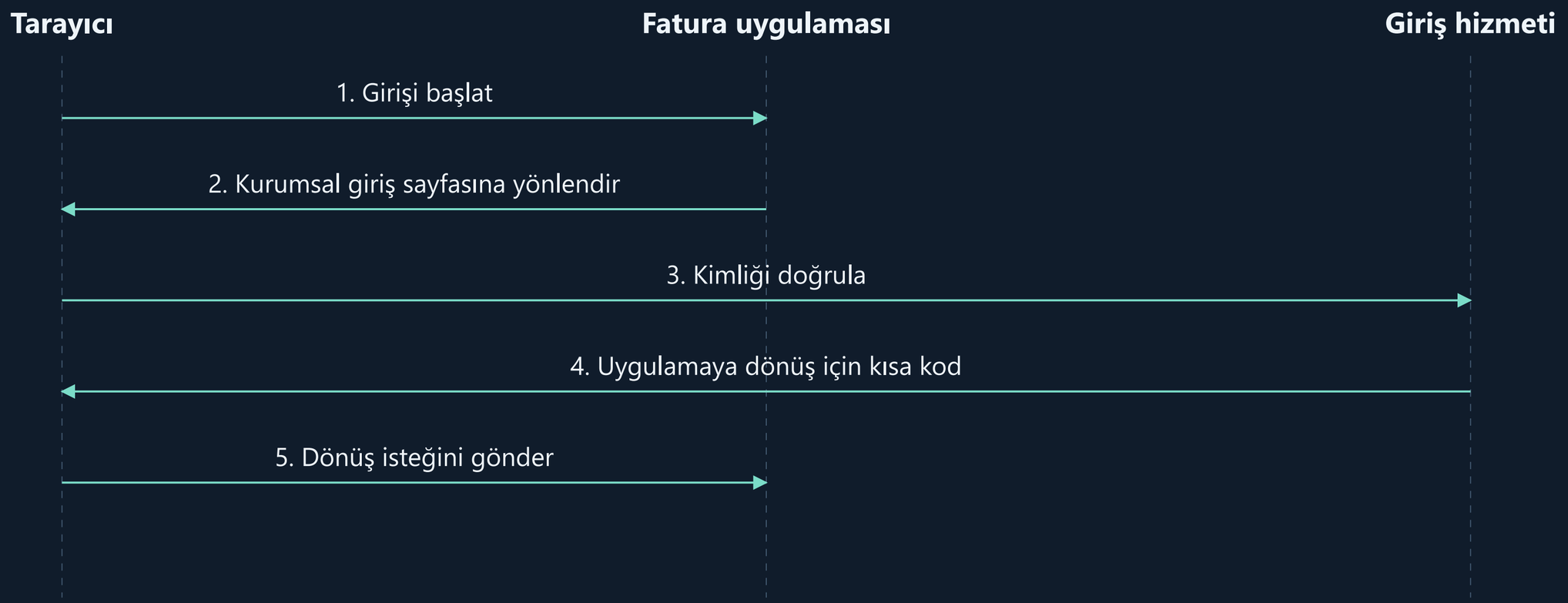
Alice, raporlama uygulamasının faturalarını okumasına izin veriyor.

- Parolasını raporlama uygulamasına vermez.
- Uygulama, izin verilen işlemler için bir erişim token'ı alır.
- Okuma izni, fatura silme izni anlamına gelmez.



RFC 6749 · OAuth 2.0

Kurumsal girişin akışı



Uygulama dönüşü doğrular, kodu token ile değiştirir ve kendi oturumunu açar. Bu işlemleri giriş kütüphanesi yürütür.

RFC 6749 · OAuth 2.0 OpenID Connect Core 1.0

Giriş sonucu, erişim ve yenileme

Değer	Ne için kullanılır?
ID token · Kimlik token’ı	Uygulama, kimin giriş yaptığını doğrular.
Access token · Erişim token’ı	Uygulama, izin verilen API işlemlerini yapar.
Refresh token · Yenileme token’ı	Uygulama yeni bir erişim token’ı alır. Her zaman verilmez.

API’ye erişim token’ı gönderilir. Kimlik token’ı API erişim belgesi olarak kullanılmaz.

RFC 6749 · OAuth 2.0 OpenID Connect Core 1.0

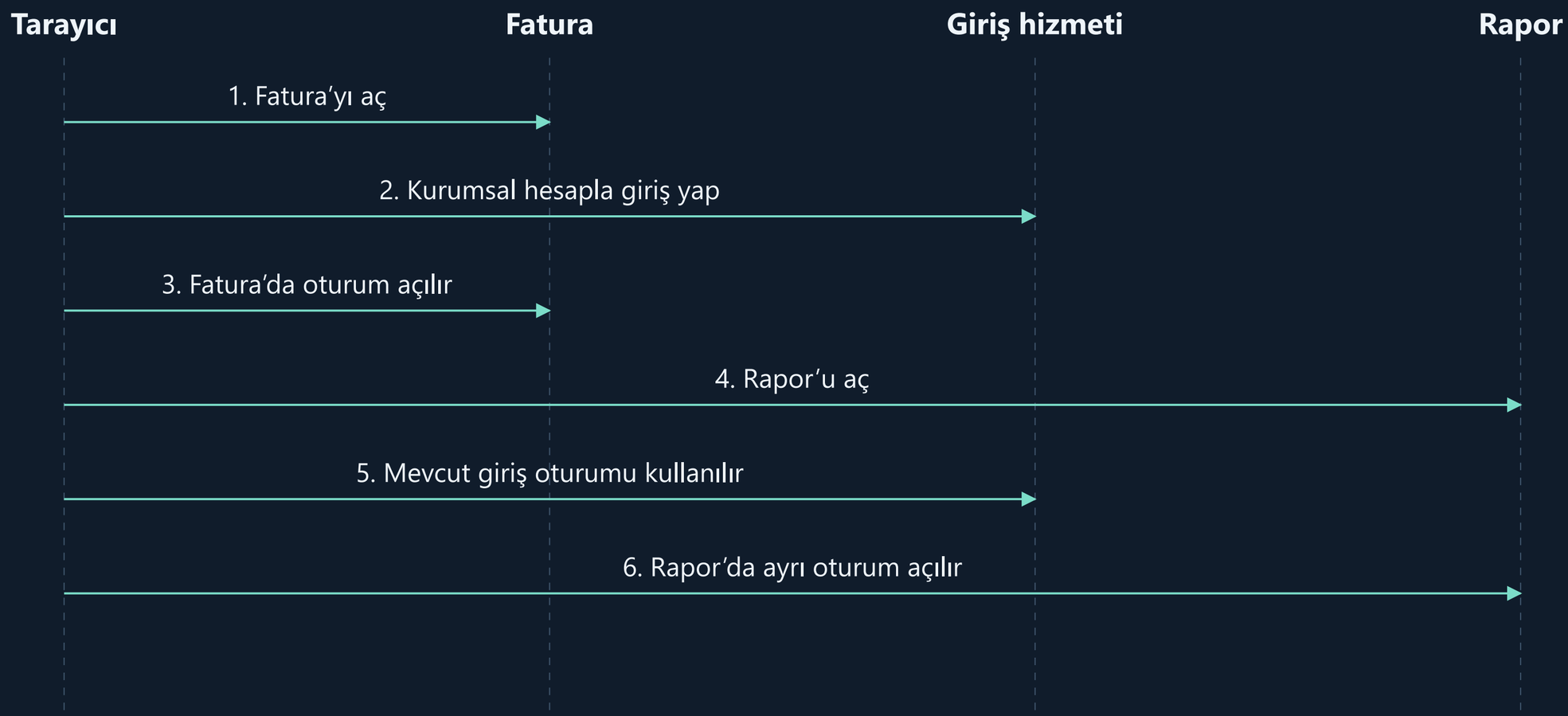
Girişte dikkat edilecekler

Kontrol	Uygulama
Dönüş adresi	Giriş hizmetinde önceden tanımlı adres kullanılır.
Giriş denemesi	Dönen yanıt, bu tarayıcıda başlatılan işlemle eşleştirilir.
Kodun kullanımı	Kodun ele geçirilmesine karşı PKCE koruması kullanılır.

PKCE · Proof Key for Code Exchange: kodu, girişi başlatan istemcinin bildiği değere bağlar. Ayrıntıları standart giriş kütüphanesine bırakıyoruz.

RFC 9700 · OAuth güvenliği RFC 7636 · PKCE

SSO: iki uygulamada tek giriş



Rapor yeniden parola istemeyebilir. Yine de kendi giriş sonucunu kontrol eder; iki uygulamanın oturumları ayrıdır.

OpenID Connect Core 1.0

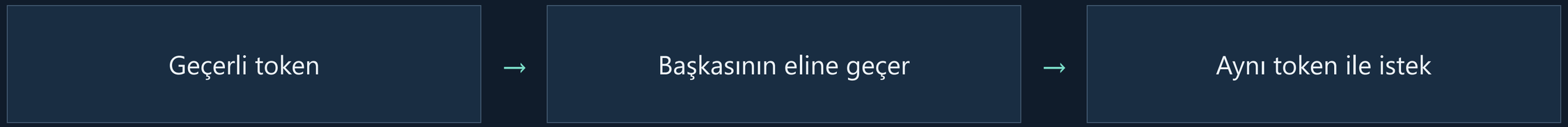
Çıkış yaptığımda ne kapanır?

İşlem	Beklenen etki
Fatura’dan çıkış	Fatura uygulamasındaki oturum kapanır.
Kurumsal girişten çıkış	Diğer uygulamalara etkisi, ortak çıkış ayarlarına bağlıdır.
Bir token’ın kopyasını saklamak	Kopyanın geçerliliği, süre ve iptal kontrollerine bağlıdır.

Deneme: Fatura’dan çıkın, Rapor’u yenileyin ve eski token ile API’ye tekrar istek gönderin.

RFC 7009 · Token iptali OpenID Connect Core 1.0

Çalınan token da kullanılabilir



Saldırganın token’ı değiştirmesi gerekmez. Geçerli bir kopyayı kullanabilir.

- Güvenli bağlantı kullanın; token’ı URL’ye veya loga yazmayın.
- Erişim süresini ve izinleri sınırlandırın.
- Sızıntıda ilgili token ve oturumları iptal edin.

RFC 6750 · Bearer token RFC 9700 · OAuth güvenliği

GitHub · çalınan entegrasyon token’ları · 2022

Heroku ve Travis CI entegrasyonlarına verilmiş OAuth token’ları çalındı. Bu token’larla özel depolara erişildi.

Entegrasyona verilen token → Token’ın ele geçirilmesi → Özel depolara erişim

Bir entegrasyona verilen yetki, o entegrasyonda saklanan token ele geçirildiğinde de kullanılabilir.

Loglama ve olay incelemesi

“If we can’t protect the Earth, you can be damn well sure we’ll avenge it.”

Alice saat 12.15’te 102 numaralı faturayı okumayı denedi. İstek reddedildi.

Zaman, kullanıcı, kaynak ve sonuç: kayıtta arayacağımız bilgiler.



The Avengers · Tony Stark · 2012

Loglar nasıl işlenir?

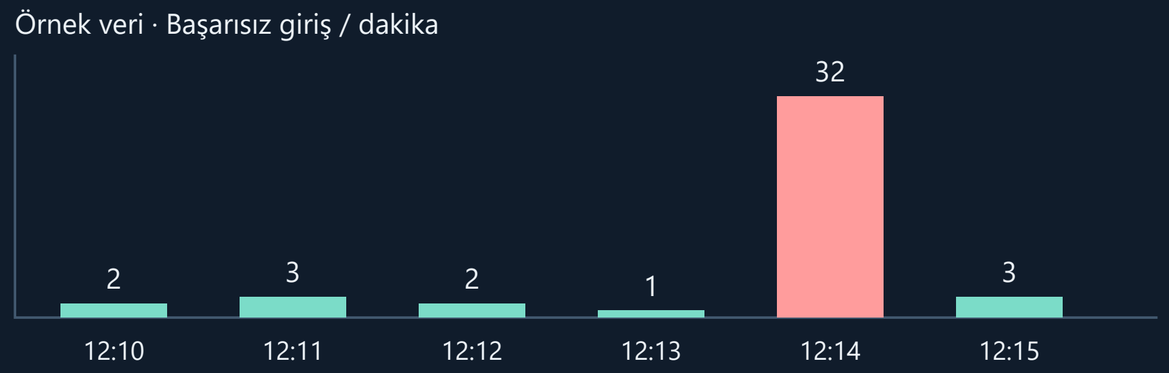
Uygulama kaydı üretir → Kayıtlar ortak yerde toplanır → Alanlara ayrılır → Arama ve grafik

Adım	Basit örnek
Toplama · Collection	Uygulama ve API kayıtları birlikte incelenebilir.
Ayrıştırma · Data parsing	Bir satırdan zaman, kullanıcı ve sonuç alanları çıkarılır.
Görselleştirme · Data visualization	Dakikadaki başarısız giriş sayısı grafiğe dökülür.

Alan adları ve zaman biçimi tutarlı olursa farklı sunucuların kayıtlarını bir arada aramak ve saymak kolaylaşır.

OWASP · Logging Cheat Sheet Microsoft · JSON verisini ayrıştırma Microsoft · Zaman grafikleri

Grafikten anomaliye



Yöntem	Ne yapar?
Basit kural	Örneğin dakikada 20'den fazla başarısız girişte alarm üretir.
ML · Machine Learning / Makine öğrenmesi	Yeterli geçmiş veriden olağan düzeni öğrenip farklı saat, hesap veya kaynaklardaki sapmaları işaretleyebilir.

Artış bir saldırı, uygulama hatası veya yoğun kullanım olabilir. Alarmın nedeni incelenir; modelin işaretlediği her olay saldırı değildir.

Microsoft · Zaman grafikleri Elastic · Makine öğrenmesiyle anomali tespiti

İşe yarayan bir log kaydı

```
{
  "time": "2026-10-26T12:15:00Z",
  "event": "invoice.read",
  "actor_id": "alice",
  "invoice_id": 102,
  "result": "denied",
  "reason": "not_owner",
  "request_id": "r-7f3c21"
}
```

Kim, ne zaman, hangi kayda erişmek istedi? Sonuç neydi, neden reddedildi?

Kullanıcı bilgisi, doğrulanmış oturumdan alınır.

OWASP · Logging Cheat Sheet

Log seviyeleri

Seviye	Ne zaman?	Örnek
DEBUG · Hata ayıklama	Ayrıntılı teşhis gerektiğinde.	Hangi işlem adımına gelindi?
INFO · Bilgi	Olağan bir olayda.	Fatura onaylandı.
WARNING · Uyarı	İncelenmesi gereken bir durumda.	Tekrarlanan erişim retleri.
ERROR · Hata	İşlem beklenmedik biçimde tamamlanamadığında.	Veritabanına ulaşılamadı.

Her başarısız giriş aynı önemde değildir. Seviye, olayın bağlamıyla seçilir.

OWASP · Logging Cheat Sheet

İsteğin tamamını loglamak

```
# Hatalı: parola, çerez ve token kayıtlara sızabilir.
logger.info("headers=%s body=%s",
            dict(request.headers), request.get_json())
```

- Authorization ve Cookie başlıkları kimlik bilgisi taşıyabilir.
- İstek gövdesi parola veya kişisel veri içerebilir.
- Kaydedeceğimiz alanları önceden seçelim.

OWASP · Logging Cheat Sheet

Seçilmiş alanlarla kayıt

```
import json

def log_denied_read(logger, user, invoice):
    event = {"event": "invoice.read",
             "actor_id": user.id,
             "invoice_id": invoice.id,
             "result": "denied"}
    logger.info(json.dumps(event, ensure_ascii=False))
```

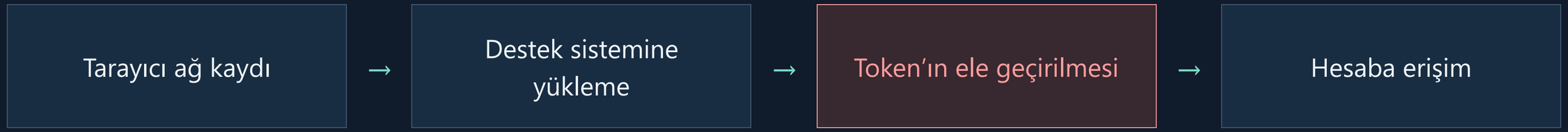
Kullanıcı doğrulanmış oturumdan gelir. Zaman ve istek kimliği log altyapısında eklenir.

JSON ile yazmak, girdideki satır sonlarının ayrı bir olay gibi görünmesini de önler.

OWASP · Logging Cheat Sheet

Okta · destek dosyasından sızan oturum · 2023

Destek için yüklenen bazı ağ kayıtlarında geçerli oturum token’ları vardı. Dosyaları ele geçiren saldırgan, bu token’larla müşteri oturumlarını kullandı.



Hata ayıklama dosyalarını paylaşmadan önce kimlik bilgilerini temizlemek gerekir.

Okta · Destek sistemi olayı · 2023

Kısa kod incelemesi

```
claims = jwt.decode(token, options={"verify_signature": False})
invoice = db.get_invoice(request.args["id"])
logger.info("token=%s", token)
return invoice.to_json()
```

Kimlik hangi satırda doğrulanıyor? Fatura kime ait? Loga hangi bilgi gidiyor?

İncelemenin sonucu

Sorun	Düzeltme
Token doğrulanmıyor.	İmza, üretici, hedef ve süre kontrol edilir.
Faturaya erişim izni yok sayılıyor.	Şirket ve sahiplik kontrolü uygulanır.
Token loga yazılıyor.	Yalnız gerekli olay alanları kaydedilir.

Yanlış token, başka kullanıcının faturası ve loga bilgi sızması ayrı ayrı denenir.

Dosya yükleme / File upload

Alice faturaya bir görsel ekliyor. Sunucu dosyanın türüne ve adına güvenebilir mi?

```
# Hatalı örnek · Sözde kod / Pseudocode
require_login()
file = request.file("attachment")
if file.content_type != "image/jpeg":
    reject(415)
file.save("/var/www/uploads/" + file.name)
return "/uploads/" + file.name
```

- Content-Type (içerik türü) başlığını istemci belirler; dosyanın gerçekten görsel olduğunu kanıtlamaz.
- Dosya adı da kullanıcı girdisidir. Hedef yolu kullanıcı seçmemeli.
- Giriş yapmak, bu faturaya dosya ekleme veya eki okuma izni vermez.

Koda bakarak tartışalım: boyut sınırı nerede, içerik nasıl doğrulanıyor, dosyaya kim erişebiliyor?

OWASP · Dosya yükleme güvenliği OWASP · Authorization Cheat Sheet

Dosyayı kabul ettik. Peki sonra?

Yükleme isteği → Özel bekleme alanı → Sunucuda kontroller → Özel depolama

Kontrol	Bu uygulamada ne yaparız?
Tür ve içerik / Type and content	Yalnız gereken türleri kabul et; uzantıyı ve gerçek içeriği birlikte doğrula.
Boyut / Size	Yükleme boyutunu sınırla; görsel boyutlarına ve işleme süresine de sınır koy.
Ad ve konum / Name and location	Sunucu yeni bir dosya adı üretir. Dosya, web kökünün dışında saklanır; kod olarak çalıştırılmaz.
Erişim / Access	Yükleme ve indirmede fatura iznini denetle. Dosya inceleme araçlarını güncel ve sınırlı yetkili tut.

Dosya yüklemek tek başına RCE değildir. Sunucu yüklenen içeriği kod olarak çalıştırırsa veya dosyayı işleyen bileşende kullanılabilir bir zafiyet varsa RCE'ye dönüşebilir.

Zafiyetlerin kralı:

RCE

Uzaktan kod çalıştırma / Remote Code Execution

Uzaktan gelen istek → Zafiyetli uygulama → Saldırganın kodu çalışır

- Dosyaları ve erişim anahtarlarını okuyabilir.
- Verileri değiştirebilir veya silebilir.
- Erişebildiği diğer servislere ilerleyebilir.

RCE otomatik olarak root veya yönetici olmak demek değildir. Kod, uygulamanın çalıştığı hesabın yetkileriyle çalışır.



MITRE · CWE-94 · Kod enjeksiyonu

Zafiyetin türü başka, etkisi başka

Zafiyetin türü / Weakness type → Kullanılma koşulu / Exploit condition → Teknik etki / Technical impact

Hata nerede?	Hangi koşulda?	Saldırgan ne yapabiliyor?
Tehlikeli dosya yükleme / Unsafe file upload	Yüklenen dosya sunucuda kod olarak çalıştırılıyor.	RCE · Uzaktan kod çalıştırma.
Komut enjeksiyonu / Command injection	Kullanıcı girdisi sunucunun çalıştırdığı komuta karışıyor.	Uygulamanın yetkileriyle komut çalıştırma; uzaktan tetiklenirse RCE.
SQL enjeksiyonu / SQL injection	Kullanıcı girdisi SQL sorgusunun yapısını değiştiriyor.	İzinsiz veri okuma veya değiştirme; otomatik olarak RCE değildir.

Kod çalıştırmanın iş etkisi: faturaların sızması, kayıtların değiştirilmesi veya hizmetin durması olabilir.

“RCE var” ifadesi etkiyi anlatır; hatanın kök nedenini tek başına açıklamaz. Aynı etki farklı zafiyet türlerinden doğabilir.

OWASP · Dosya yükleme güvenliği MITRE · CWE-89 · SQL enjeksiyonu MITRE · CWE-94 · Kod enjeksiyonu

Bir RCE örneği: Log4Shell

Log4j’nin etkilenen sürümlerinde özel hazırlanmış bir log girdisi, koşullar uygunsa uzaktan kod çalıştırılmasına yol açabiliyordu.

Saldırganın girdisi → Zafiyetli Log4j bileşeni → Sunucuda kod çalışması

Zafiyetin nedeni / Weakness	Teknik etki / Technical impact
Güvenilmeyen log verisi, saldırganın denetlediği dış kaynaklara başvuran arama (lookup) mekanizmasını tetikleyebiliyordu.	RCE · Uygulamanın çalıştığı makinede saldırganın kodu çalışabiliyordu.

CVE-2021-44228 · 2021. Veri olarak kaydedilmesi gereken girdi, kod çalıştırmaya uzanan bir işlem zincirini başlatıyordu.

RCE farklı zafiyetlerden doğabilir: komut enjeksiyonu, güvensiz veri işleme veya bellek hataları. Log4Shell burada yalnız bir örnek.

Apache · Log4Shell · CVE-2021-44228 MITRE · CWE-94 · Kod enjeksiyonu

Sorular ve tartışma

Bir token geçerliyken erişim neden reddedilebilir?

Bir uygulamadan çıkınca diğeri neden açık kalabilir?

Token’ı kaydetmeden bir olayı nasıl inceleriz?



Kaynaklar

RFC 6749 · OAuth 2.0

RFC 9700 · OAuth güvenliği

RFC 7519 · JWT

RFC 8725 · JWT güvenliği

RFC 7518 · Anahtarlar ve algoritmalar

OpenID Connect Core 1.0

OWASP · Logging Cheat Sheet

Elastic · Makine öğrenmesiyle anomali tespiti

GitHub · OAuth token hırsızlığı · 2022

Okta · Destek sistemi olayı · 2023

OWASP · Dosya yükleme güvenliği

Apache · Log4Shell · CVE-2021-44228